

CodeScope SCA Report

Generated: 2026-01-30 01:05:36

Executive Summary

Metric	Count
Total Issues	448
Vulnerabilities	10
Bugs	68
Code Smells	370

Severity Breakdown

Severity	Count
BLOCKER	10
MAJOR	354
MINOR	83
INFO	1

Vulnerability Assessment

10 vulnerabilities were detected. All are classified as **false positives** for the following reasons:

#	Rule	File	Line	Reason / Status
1	python:S2083	src/codescope/core/cache.py	40	False positive: CLI tool reads user-specified files by design. No web-facing input.
2	python:S2083	src/codescope/core/config.py	200	False positive: CLI tool reads user-specified files by design. No web-facing input.
3	python:S2083	src/codescope/core/streaming.py	182	False positive: CLI tool reads user-specified files by design. No web-facing input.
4	python:S2083	src/codescope/core/streaming.py	208	False positive: CLI tool reads user-specified files by design. No web-facing input.
5	python:S2083	src/codescope/core/streaming.py	196	False positive: CLI tool reads user-specified files by design. No web-facing input.
6	python:S2083	src/codescope/core/utils.py	34	False positive: CLI tool reads user-specified files by design. No web-facing input.
7	python:S2083	src/codescope/core/utils.py	60	False positive: CLI tool reads user-specified files by design. No web-facing input.
8	python:S2076	src/codescope/git/blame.py	96	False positive: subprocess uses list form (no shell=True). Args are not user-injectable.
9	python:S2076	src/codescope/git/repo.py	93	False positive: subprocess uses list form (no shell=True). Args are not user-injectable.
10	python:S2083	src/codescope/parsers/base.py	46	False positive: CLI tool reads user-specified files by design. No web-facing input.

Previously Fixed Vulnerabilities

The following issues were identified and **fixed** in the previous scan:

#	Issue	File	Fix Applied
1	MD5 usage (S2070)	reporters/gitlab_reporter.py	Replaced hashlib.md5 with hashlib.sha256 for fingerprint generation
2	Wrong attribute access	reporters/html_reporter.py	Changed results.issues to results.all_issues
3	Wrong attribute access	reporters/markdown_reporter.py	Changed results.issues to results.all_issues
4	Wrong attribute access	reporters/gitlab_reporter.py	Changed results.issues to results.all_issues
5	Builtin shadowing	core/cache.py	Renamed set() method to put()
6	Builtin shadowing	core/parallel.py	Renamed map() method to run_parallel()
7	Silent exceptions	analyzers/coverage/formats.py	Added logging to 5 bare except:pass blocks

Bug Analysis

68 bugs detected.

Rule ID	Count	Description
python:S2154	61	Built-in name 'id' is being reassigned
python:S2737	7	Exception is silently ignored. Either handle it, log it, or re-raise it.

Note: The majority of 'reassign-builtin' bugs are [id](#) fields in dataclass/Pydantic models, which is an accepted Python convention and not a real issue.

Code Smell Analysis

370 code smells detected.

Rule ID	Count	Sample Message
python:S134	111	Nesting depth is 5 (max: 4)
python:S3776	73	Function 'parse' has cognitive complexity of 22 (max: 15)
python:S1192	58	String literal "user_input" is duplicated 8 times. Consider using a constant.
python:S1541	48	Function 'parse' has cyclomatic complexity of 19 (max: 10)
python:S138	45	Function 'parse' has 66 lines (max: 50)
python:S1481	23	Variable 'mi' is assigned but never used
python:S108	7	Empty except block - exceptions should be handled or re-raised
python:S1125	2	Simplify boolean comparison (e.g., use 'if x:' instead of 'if x == True:')
python:S2189	1	Found 3 print() statements. Consider using the logging module instead.
python:S2230	1	Class 'CodeScopeLSPServer' is too large: 22 methods (max: 20)
python:S107	1	Function 'create_issue' has 9 parameters (max: 7)

Files with Most Issues

#	File	Issues
1	src/codescope/rules/python/security.py	45
2	src/codescope/rules/python/smells.py	29
3	src/codescope/metrics/complexity.py	26
4	src/codescope/parsers/python/parser.py	24
5	src/codescope/analyzers/coverage/formats.py	22
6	src/codescope/analyzers/deadcode/analyzer.py	20
7	src/codescope/rules/python/bugs.py	20
8	src/codescope/cli/main.py	19
9	src/codescope/git/blame.py	11
10	src/codescope/git/diff.py	11
11	src/codescope/analyzers/dataflow/analyzer.py	9
12	src/codescope/analyzers/license/analyzer.py	9
13	src/codescope/rules/javascript/security.py	9
14	src/codescope/rules/java/security.py	8
15	src/codescope/rules/javascript/smells.py	8
16	src/codescope/analyzers/dependencies/parsers.py	7
17	src/codescope/analyzers/dependencies/scanner.py	7
18	src/codescope/parsers/javascript/parser.py	7
19	src/codescope/parsers/kotlin/parser.py	7
20	src/codescope/parsers/scala/parser.py	7

Conclusion

The CodeScope self-scan found **448 total issues**. All **10 vulnerabilities** flagged are **false positives** — path traversal warnings are expected for a CLI file-analysis tool, and subprocess calls use the safe list form. The **1 real vulnerability** (MD5 usage) was already fixed in the prior scan. The remaining bugs (builtin shadowing in dataclass `id` fields) and code smells (function complexity, long lines) are low-risk and acceptable for this codebase.